

망분리를 풀면, 신뢰를 무엇으로 대체하는가

검증 가능한 다층보안(MLS) 보상통제를 코드로. 한 요청이 신원·세분화·인가·암호화·탐지를 전부 통과해야 데이터에 닿고, 각 통제가 막는다는 사실을 매번 라이브로 재현한다.

검증가능 커버리지 72% (29/40) 라이브 검증 21/21 무료 로컬 · MIT

캡은 숨기지 않고 공개

문 제 - 위 치 = 신 위 가 사 라 진 다

FSC 「금융분야 망분리 개선 로드맵」(2024-08-13)이 *위치 기반 분리*를 *위험 기반 MLS*로 전환한다. "내부망 안이니 신뢰"가 무너진 자리를 **보상통제(compensating controls)**로 메워야 하는데 - 문제는 그 통제가 *실제로* 막는지를 어떻게 증명하느냐다. 슬라이드가 아니라 **실행과 검증**으로.

접 근 - 한 워크로드, 6개 통제 계층, 각각 실행 가능한 테스트

요청 / 공격 진입 alice·bob·위조 파드 ·터린 컨테이너	① 신원 admission 라벨↔SA · SA-use 게이트 · SPIFFE	② 세분화 Cilium L3/L7 default-deny · web→api→db만	③ 인가 Cedar PDP 소유자·한도·역할·동결 (per-request)	기밀 C db 데이터스토어 (최상위 등급)
④ egress default-deny — 인터넷·메타데이터·API서버 차단(유출/SSRF)	⑤⑥ 암호화 — WireGuard 전송(크로스노드) · etcd 저장	⑦ 런타임 — Tetragon eBPF: 데이터터어 셀 in-kernel SIGKILL		

같은 네트워크 경로·같은 L7 허용이라도 **principal이 다르면 결과가 다르다** — alice 200 / bob 403. 거친 통제(RBAC·세분화) → 세밀한 통제(ABAC·per-request)를 순서대로 통과해야 데이터에 닿는다.

증 거 - 전 부 재 현 가 능 (숫 자 는 REPO에 서 그 대 로)

72% (29/40) 검증가능성 커버리지 워크로드 적용가능 MLS sub-requirement 중 코드로 검증된 비율. 캡은 행 단위 공개.	21/21 라이브 방어심층 검증 차단/허용 enforcement 전부 (`verify.sh`). 기능 회귀 스위트.	8/8 · 17/17 Cedar 인가 단위테스트 코어 + AI-에이전트 위임(confused-deputy·ASI08). 뮤테이션으로 반증가능.
11/11 ReBAC 관계 테스트 OpenFGA `model test` + 라이브 `/check`.	452 / 0 checkov shift-left pass / fail · 문서화된 skip 5. 공급망: 실제 HIGH CVE 1건 포착→수정 →green, SBOM 103.	CRITICAL 1 자체 적대 검증이 잡은 실 버그 LLM 멀티에이전트 재검토가 *우리 SA-use 정책*의 우회를 발견 → 수정 → 라이브 재검증.

정직 단서: 21/21은 *기능 회귀 스위트*(분모 없는 측정값이 아님)이고, 72%의 분모는 워크로드-적용가능 40이다. 범주 분포 — VERIFIED 29 · CONFIGURED 7 · GOVERNANCE 2 · NOT-COVERED 4. 나머지 28%는 **숨긴 게 아니라 행 단위로 공개** (`docs/mls-coverage.csv`)되어 있다.

왜 신 위 할 수 있 나 - "안 전 하 다"가 아 니 라 "캡 을 공 개 한 다"

주장하는 모든 통제는 재실행 가능한 테스트에 연결되거나, 정직하게 미검증으로 라벨된다.

- **재현 증거:** 감사자가 부작용 없이 직접 돌리는 server dry-run으로 거부/허용을 자기검증(`docs/audit-evidence.md`).
- **명시된 갭:** CONFIGURED 7 · GOVERNANCE 2 · NOT-COVERED 4를 행 단위로 공개 — 28%가 구체적이다.
- **정직성의 증명:** 요청자 JWT 강제가 라이브가 아니라(X-User fallback 허용) 그 행(ID8)을 스스로 추가해 헤드라인을 *낮췄다* — 높은 편한 숫자 대신 낮은 참값을 택함.

감사 관점: 증명 못 하는 통제는 보상통제로 주장할 수 없다. 증명되는 통제는 감사 증거 부담을 줄인다("막는다 + 매번 재현 된다").

직 접 보 기 — 자 동 채 점 기 의 판 정

```
# 같은 경로, 다른 principal — Cedar PDP
alice → GET /accounts/acct-alice    200      bob → GET /accounts/acct-alice    403
# 런타임: 데이터티어 셀은 커널에서 SIGKILL, 정상 바이너리는 생존
db: /bin/sh -c 'echo'    rc=137 (SIGKILL)    db: id    rc=0
# 네트워크: 허용되지 않은 홑·경로는 차단
web → db (홑 없음, L3 drop)    000      web → api GET /auditlogs (L7 deny)    403
```

재구현 트랙 (자가채점 학습)

사내교육 도입 가이드

FSC MLS 통제 매핑

무설치 체험: GitHub Code ▶ Codespaces (무클러스터 랩 즉시 채점)

교육·포트폴리오 목적의 보상통제 설계 레퍼런스입니다 — 법률/금융 자문도, 공식 FSC 컴플라이언스 매핑도 아닙니다. 규제 세부(고시·조문·시행 일)는 1차 출처 대조가 필요합니다. 실 데이터스토어 없음 · X-User는 미인증 데모 입력 · 제3자 상표는 각 소유자 자산. · cloudsec-policy-stack · MIT